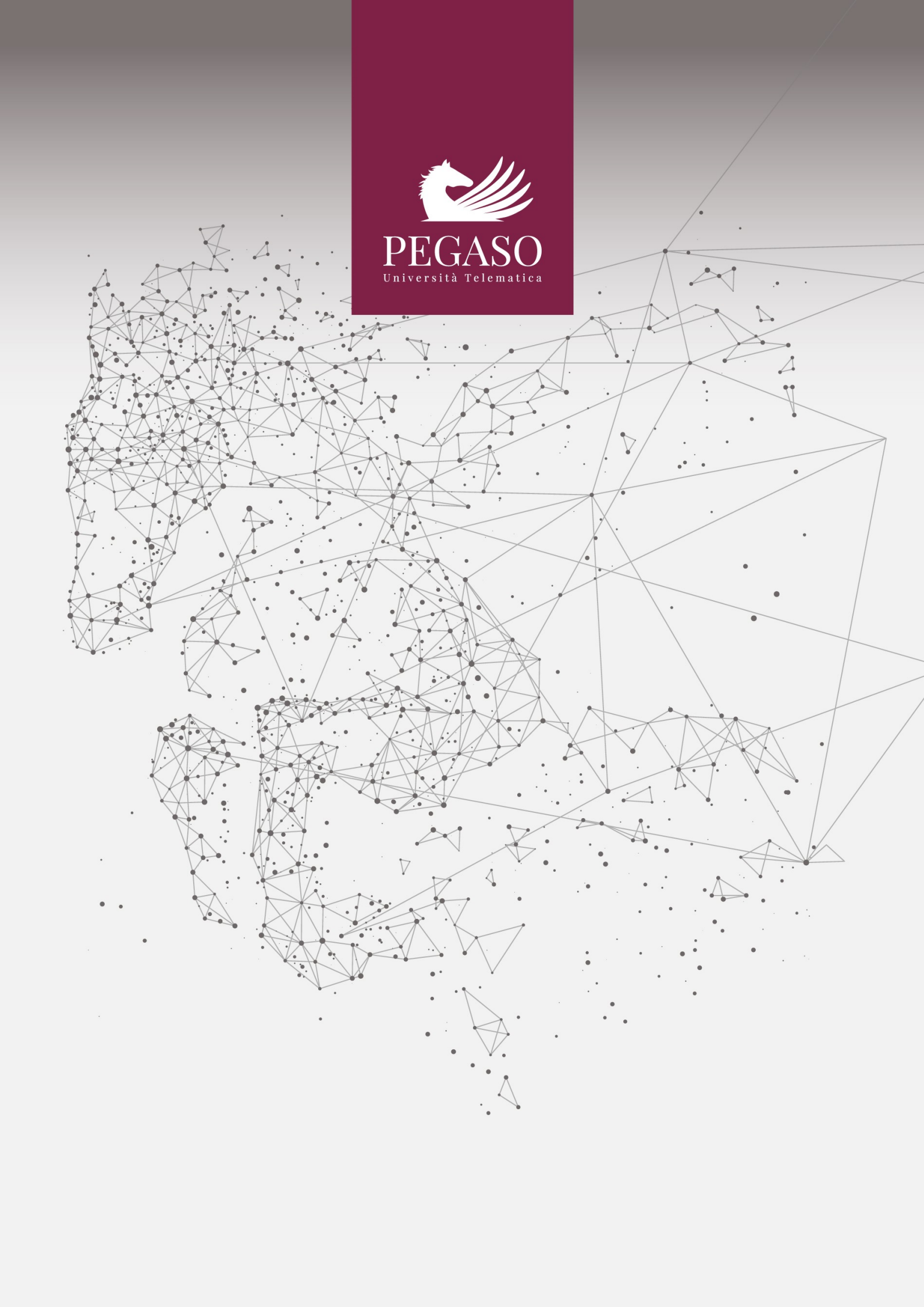

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 SEGRETEZZA E CRITTOGRAFIA SIMMETRICA: INTRODUZIONE 3

2 CRITTOGRAFIA DI CANALE E END-TO-END 5

3 DISTRIBUZIONE DELLE CHIAVI 6

4 UN ESEMPIO DI DISTRIBUZIONE DELLE CHIAVI 7

BIBLIOGRAFIA 9

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Segretezza e crittografia simmetrica: introduzione

La crittografia simmetrica è da sempre utilizzata per garantire la segretezza delle informazioni, sebbene ultimamente sia usata anche per applicazioni come l'autenticazione. In particolare, due sono gli aspetti fondamentali da tenere in considerazione:

- il punto in cui posizionare la logica di crittografia
- cosa crittografare

Per ciò che riguarda il posizionamento dei sistemi crittografici, due sono sostanzialmente gli approcci seguiti:

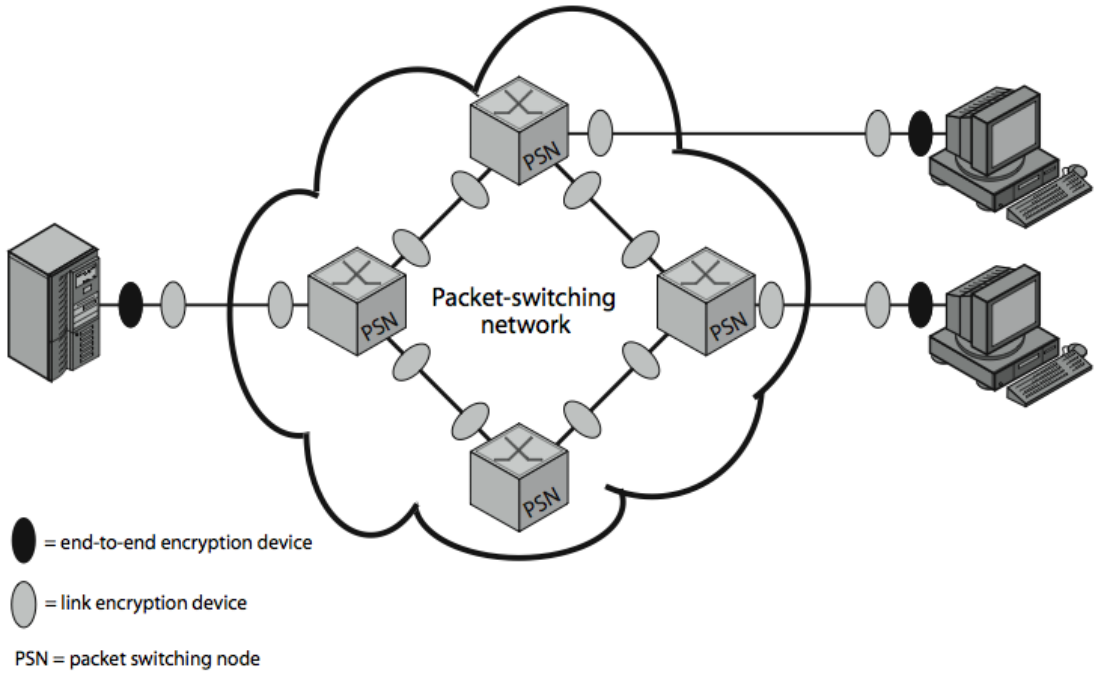
- **la crittografia di canale**
- **la crittografia end-to-end**

I vari punti di una rete locale e i loro collegamenti costituiscono dei possibili elementi di vulnerabilità che vanno adeguatamente protetti. Diventa talvolta difficile individuare i punti con maggiore criticità in quanto questa dipende sia dal tipo di funzione svolta sia dal legame con gli altri elementi della rete. Un attacco può verificarsi in qualsiasi punto dell'infrastruttura di comunicazione. Basta pensare che per svolgere un attacco passivo, un attaccante deve semplicemente riuscire ad osservare le trasmissioni che avvengono su un determinato collegamento sia essa in cavo o senza fili.

Nella figura di seguito sono evidenziati i punti in cui i sistemi di crittografia di canale (link encryption) e quelli di crittografia end-to-end possono essere posizionati all'interno di una determinata infrastruttura di collegamento di rete.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Si può facilmente notare che, per esempio, i sistemi di crittografia end-to-end si trovano appunto all'estremità di un collegamento fra due host e non coinvolgono i vari collegamenti fra dispositivi collocati all'interno dell'architettura di rete.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Crittografia di canale e end-to-end

Nel caso della **crittografia di canale** ogni collegamento vulnerabile fra due dispositivi viene dotato, a entrambe le estremità, di un sistema di crittografia. Ciò determina varie problematiche tra cui la necessità di un grande numero di dispositivi di crittografia ma soprattutto che ogni coppia di nodi che condivide un collegamento deve avere una chiave univoca condivisa e diversa per ogni collegamento. Si capisce bene che conseguentemente si devono utilizzare un enorme quantità di chiavi crittografiche L'altro aspetto problematico riguarda il fatto che tutte le volte che il messaggio entra in uno switch di rete, esso deve essere decifrato, infatti lo switch deve poter leggere l'indirizzo (numero di connessione logica) contenuto nell'intestazione del pacchetto e ciò rende il messaggio vulnerabile ed esposto a possibili attacchi.

Nel caso della **crittografia end-to-end** il processo di crittografia viene eseguito solo dai due sistemi terminali; il terminale sorgente e quello di destinazione condividono la chiave segreta di cifratura/decifratura. Si capisce immediatamente che ciò riduce di molto il problema della numerosità dei dispositivi ma dall'altro lato si ha che l'intestazione è in chiaro, ovvero i dati utente sono sicuri ma non il loro flusso nella rete che può essere osservato da un attaccante per estrarre informazioni sulla frequenza dei messaggi, sugli host coinvolti in termini di tempi e tipologia di connessioni.

Ne consegue che entrambi i tipi di crittografia sono necessari per garantire la massima sicurezza. In tal caso, l'host prima esegue la crittografia dei dati utente tramite la chiave di crittografia end-to-end e poi cifra l'intero pacchetto mediante la chiave di crittografia di canale.

In termini di livelli OSI (Open Systems Interconnection) la crittografia di canale viene eseguita a livelli molto bassi della gerarchia di comunicazione, come il *livello fisico* o il *livello di collegamento*. Al contrario, la codifica di tipo end-to-end viene inserita a livelli più alti della gerarchia OSI ma con differenti possibilità di scelta; può essere inserita sia a *livello di rete* (caso di livello più basso) oppure a livelli superiori fino al *livello di applicazione* come avviene nel caso della posta elettronica.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Distribuzione delle chiavi

L'uso della crittografia simmetrica prevede che le due parti condividano la stessa chiave segreta crittografica, diventa pertanto importante stabilire come distribuire tale chiave in maniera sicura ai due partecipanti alla trasmissione. Infatti succede che talvolta il sistema di crittografia è molto sicuro ma il metodo di distribuzione delle chiavi non lo è e ciò ovviamente inficia la robustezza dell'intero sistema crittografico.

La distribuzione della chiave fra due utenti A e B può avvenire in vari modi:

1. A sceglie una chiave e la consegna *fisicamente* a B
2. Una «terza parte» può scegliere la chiave e consegnarla *fisicamente* ad A e B
3. Se A e B sono già in possesso di una chiave condivisa possono usarla per scambiarsi la nuova
4. Se A e B hanno già un canale crittografato verso una terza parte C, quest'ultima può consegnare loro una chiave tramite tali canali

Le opzioni 1 e 2 richiedono la consegna manuale di una chiave e se queste possono avere senso per una crittografia di canale, certamente diventano improponibili per quella end-to-end, in quanto ogni host si troverà a dover scambiare dati con molti altri host. Se vi sono N host che devono comunicare tra di loro, il numero di chiavi sarà [N(N-1)]/2: per esempio, se N=1000 allora serviranno circa mezzo milione di chiavi!

L'opzione 3 può essere usata per entrambi le tipologie di crittografia ma se un estraneo dovesse riuscire ad ottenere l'accesso a una chiave, individuerebbe anche tutte le chiavi successive.

Per la crittografia end-to-end sono adottate delle varianti dell'opzione 4: la distribuzione è basata su una gerarchia di chiavi. Al minimo ci sono due livelli: una *chiave di sessione*, usata solo per la durata della connessione logica e una *chiave master* condivisa e distribuita da una terza parte e usata per cifrare la chiave di sessione. Così servono solo N *chiavi master* per ogni entità.

PEGASO
Università Telematica

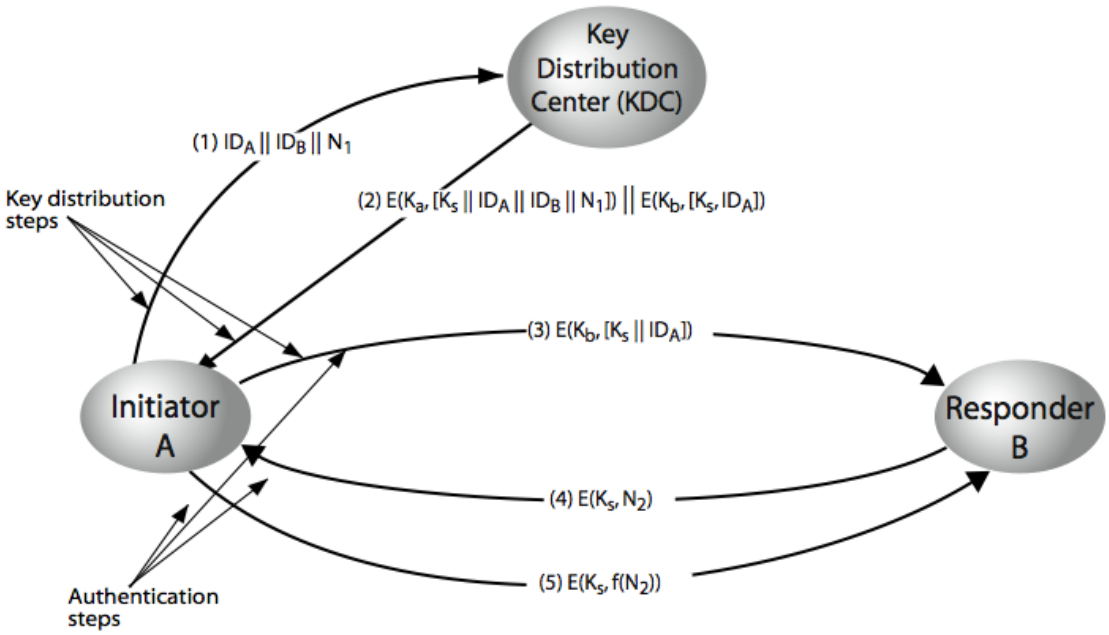
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

4 Un esempio di distribuzione delle chiavi

Vediamo adesso un esempio di meccanismo di distribuzione delle chiavi.

Si suppone che ciascun dei due utenti A e B condivida con il KDC (Key Distribution Center) una chiave master univoca, ovvero K_A e K_B sono note solo all'utente e al KDC.

Come evidenziato nella figura sottostante, A invia al KDC la sua identità, quella di B e un *nonce* N_1 (identificatore univoco, per esempio l'orario, un numero casuale). Il KDC risponde con messaggio cifrato con la chiave K_A, solo A è in grado di decifrarlo.



Tale messaggio contiene:

- la chiave di sessione K_S che A memorizza
- il messaggio originale (per associare tale risposta alla richiesta corretta, grazie alla presenza del *nonce*)
- due elementi destinati a B, cifrati con la chiave K_B ovvero la chiave di sessione K_S e l'identità di A

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Solo B può decifrare tale messaggio che contiene i due elementi a lui inoltrati da A e quindi alla fine:

- B possiede la chiave di sessione
- B conosce l'identità di A garantita dal KDC

Tuttavia per garantire B dalla possibilità di avere ricevuto una replica si effettuano i seguenti due ulteriori passi:

- B invia ad A un *nonce* N_2 cifrato con K_S
- A risponde con una trasformazione di N_2, $f(N_2)$ (per esempio aggiunge 1) cifrato con K_S

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 7*.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).